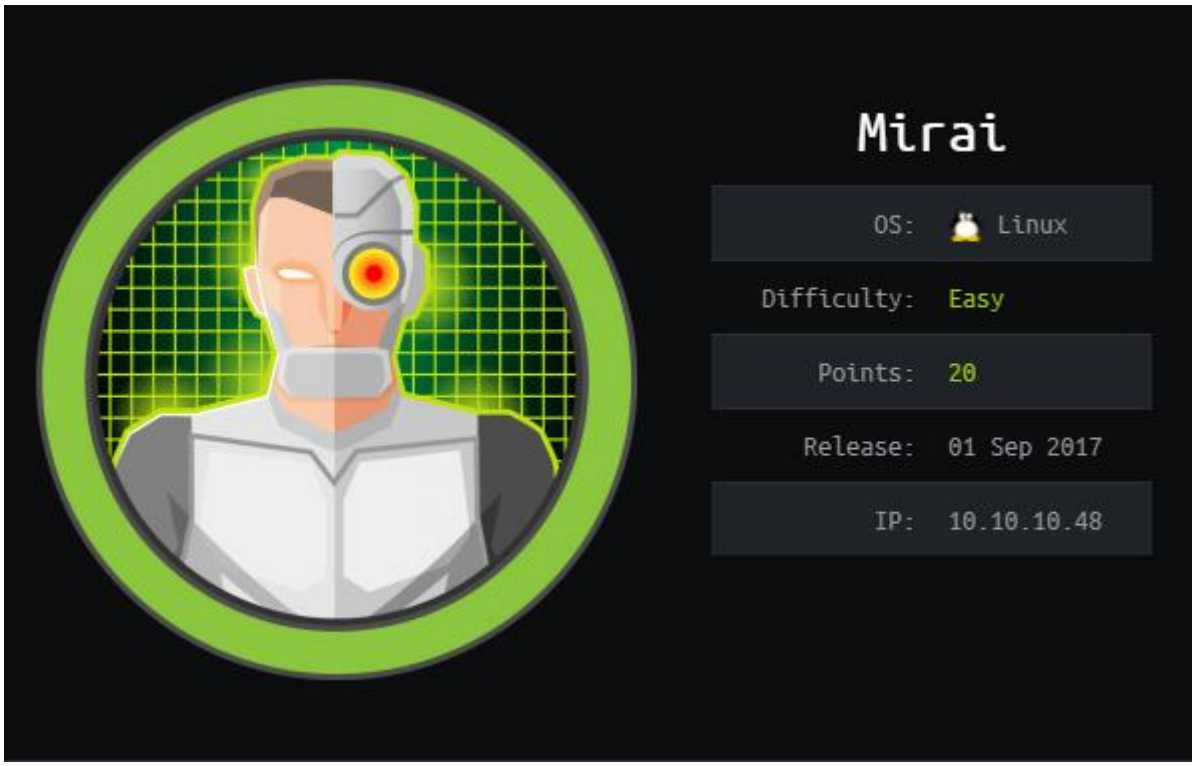

Mirai identifies vulnerable IoT devices using a table of more than 60 common factory default usernames and passwords, and logs into them to infect them with the Mirai malware

Date: 08/02/2022

By: Wael Ghnimi

Vulnerability Exploited: **Vendor Default Credentials**

System Vulnerable: 10.10.10.48

Vulnerability Explanation: It is possible to access the machine using ssh using the default credential of the raspberry pi. Raspberry Pi OS through 5.10 has the raspberry default password for the pi account. If not changed, attackers can gain administrator privileges.

Vulnerability Fix: Always change the default password of the user and the root with any new installation.

Privilege Escalation Vulnerability: No need for Priv Esc

Vulnerability Fix: The developer should have conformed to the principle of least privilege and the concept of separation of privileges.

Severity: **Critical**

An initial nmap scan revealed the lighttpd 1.4.35 running on port 80 and ssh on port 22.

```
# Nmap 7.92 scan initiated Mon Jan 24 05:37:52 2022 as: nmap -sC -sV -v -oN nmap/initial 10.10.10.48
Nmap scan report for 10.10.10.48
Host is up (0.13s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 6.7p1 Debian 5+deb8u3 (protocol 2.0)
| ssh-hostkey:
|   1024 aa:ef:5c:e0:8e:86:97:82:47:ff:4a:e5:40:18:90:c5 (DSA)
|   2048 e8:c1:9d:c5:43:ab:fe:61:23:3b:d7:e4:af:9b:74:18 (RSA)
|   256 b6:a0:78:38:d0:c8:10:94:8b:44:b2:ea:a0:17:42:2b (ECDSA)
|_  256 4d:68:40:f7:20:c4:e5:52:80:7a:44:38:b8:a2:a7:52 (ED25519)
53/tcp open  domain  dnsmasq 2.76
| dns-nsid:
|_  bind.version: dnsmasq-2.76
80/tcp open  http    lighttpd 1.4.35
| http-methods:
|_  Supported Methods: OPTIONS GET HEAD POST
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_http-server-header: lighttpd/1.4.35
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Mon Jan 24 05:38:16 2022 -- 1 IP address (1 host up) scanned in 23.34 seconds
```

Using the default of raspberry pi, the default password and username of ssh are **pi:raspberry**

Establish an ssh connection using the user pi:

```
pi@raspberrypi:~ $ id
uid=1000(pi) gid=1000(pi)
groups=1000(pi),4(adm),20(dialout),24(cdrom),27(sudo),29(audio),44(video),46(plugdev),60(games),100(users),101
(input),108(netdev),117(i2c),998(gpio),999(spi)
pi@raspberrypi:~ $ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:b9:e6:10
          inet addr:10.10.10.48  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::74dd:973a:91e9:2497/64 Scope:Link
          inet6 addr: fe80::250:56ff:feb9:e610/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:401175 errors:32 dropped:167 overruns:0 frame:0
          TX packets:388235 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:48116445 (45.8 MiB)  TX bytes:107778383 (102.7 MiB)
          Interrupt:19 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:17661 errors:0 dropped:0 overruns:0 frame:0
          TX packets:17661 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:5432385 (5.1 MiB)  TX bytes:5432385 (5.1 MiB)
```

user.txt

```
pi@raspberrypi:~/Desktop $ cat user.txt  && hostname && whoami && ip a
ff837707441b257a20e32199d7c8838draspberrypi
pi
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN group default qlen 1000
    link/ether 00:50:56:b9:e6:10 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.48/24 brd 10.10.10.255 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:e610/64 scope link
       valid_lft forever preferred_lft forever
    inet6 fe80::74dd:973a:91e9:2497/64 scope link
       valid_lft forever preferred_lft forever
```

```
pi@raspberrypi:~/Desktop $ cat user.txt  && hostname && whoami && ip a
ff837707441b257a20e32199d7c8838draspberrypi
pi
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN group default qlen 1000
    link/ether 00:50:56:b9:e6:10 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.48/24 brd 10.10.10.255 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:e610/64 scope link
       valid_lft forever preferred_lft forever
    inet6 fe80::74dd:973a:91e9:2497/64 scope link
       valid_lft forever preferred_lft forever
```

Privilege Escalation

Checking the permissions the **pi** user had:

```
pi@raspberrypi:~/Desktop $ sudo -l
Matching Defaults entries for pi on localhost:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User pi may run the following commands on localhost:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: ALL
```

Run sudo su and get the root privilege

```
pi@raspberrypi:~/Desktop $ sudo su
root@raspberrypi:/home/pi/Desktop# whoami && id
root
uid=0(root) gid=0(root) groups=0(root)
root@raspberrypi:/home/pi/Desktop#
```

Showing the content of root.txt gives that the root flag is on the USB Stick.

```
root@raspberrypi:~# cat root.txt
I lost my original root.txt! I think I may have a backup on my USB stick...
```

To check the attached devised to the system as well as its mount points, you can run the **df** command as the following:

```
root@raspberrypi:/dev# df -h
Filesystem      Size  Used Avail Use% Mounted on
aufs            8.5G  2.8G  5.3G  35% /
tmpfs           100M  8.8M   92M   9% /run
/dev/sda1       1.3G  1.3G     0 100% /lib/live/mount/persistence/sda1
/dev/loop0      1.3G  1.3G     0 100% /lib/live/mount/rootfs/filesystem.squashf
tmpfs           250M     0  250M   0% /lib/live/mount/overlay
/dev/sda2       8.5G  2.8G  5.3G  35% /lib/live/mount/persistence/sda2
devtmpfs         10M     0   10M   0% /dev
tmpfs           250M  8.0K  250M   1% /dev/shm
tmpfs           5.0M  4.0K  5.0M   1% /run/lock
tmpfs           250M     0  250M   0% /sys/fs/cgroup
tmpfs           250M  8.0K  250M   1% /tmp
/dev/sdb        8.7M   93K  7.9M   2% /media/usbstick
tmpfs            50M     0   50M   0% /run/user/999
tmpfs            50M     0   50M   0% /run/user/1000
```

The USB strick is on /dev/sdb and mounted on /media/usbstick

The file was deleted, we need to get them back:

```
root@raspberrypi:/media/usbstick# ls
damnit.txt  lost+found
root@raspberrypi:/media/usbstick# cat damnit.txt
Damnit! Sorry man I accidentally deleted your files off the USB stick.
Do you know if there is any way to get them back?

-James
```

Using $ cat sdb file on /dev/ directory we can see the previous content of the USB stick:

```
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
/media/usbstick
2]8^
lost+found
root.txt
damnit.txt
>r &
3d3e483143ff12ec505d026fa13e020b
Damnit! Sorry man I accidentally deleted your files off the USB stick.
Do you know if there is any way to get them back?
-James
```

root.txt Proof

```
root@raspberrypi:/dev# strings sdb | grep -i 3d3e483143ff12ec505d026fa13e020b && hostname && whoami && ip a
3d3e483143ff12ec505d026fa13e020b
raspberrypi
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN group default qlen 1000
    link/ether 00:50:56:b9:e6:10 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.48/24 brd 10.10.10.255 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:e610/64 scope link
       valid_lft forever preferred_lft forever
    inet6 fe80::74dd:973a:91e9:2497/64 scope link
       valid_lft forever preferred_lft forever
```


```
root@raspberrypi:/dev# strings sdb | grep -i 3d3e483143ff12ec505d026fa13e020b && hostname && whoami && ip a
3d3e483143ff12ec505d026fa13e020b
raspberrypi
root
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN group default qlen 1000
    link/ether 00:50:56:b9:e6:10 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.48/24 brd 10.10.10.255 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:feb9:e610/64 scope link
       valid_lft forever preferred_lft forever
    inet6 fe80::74dd:973a:91e9:2497/64 scope link
       valid_lft forever preferred_lft forever
```

Lessons Learned
To gain an initial foothold on the box we exploited two vulnerabilities. 1. Use of default credentials. The user used the default password that is shipped with the application. Since default credentials are publicly available and can be easily obtained, the user should have instead used a sufficiently long password that is difficult to crack. 2. Always separate the privileges from the normal user and the administrators' users.